

## 5.4 Password Repository Protection

| Control Type: Mandatory                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Applies to architecture: | A1 | A2 | A3 | A4 | B |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|----|----|----|----|---|
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                          | •  | •  | •  | •  | • |
| <p><b>Control Definition</b></p> <p><b>Control Objective:</b> Protect physically and logically the repository of recorded passwords.</p> <p><b>In-scope components:</b></p> <p>Repository recording accounts and passwords defined on the following components:</p> <ul style="list-style-type: none"> <li>dedicated and general-purpose operator PC</li> <li>jump server</li> <li>Swift-related components (including interfaces, GUI, Swift and customer (client) connectors and their activation codes or licence keys)</li> <li>customer client connector</li> <li>systems or virtual machines hosting Swift-related components</li> <li>HSM, related tokens, Luna Backup HSM and Alliance Connect Virtual on Premises vTPM backups</li> <li>network devices protecting the secure zone or the customer client connectors</li> <li>on-premises or remote (that is hosted or operated by a third party, or both) virtualisation or cloud platform hosting Swift-related VMs, including the Alliance Connect Virtual on Premises VPN</li> <li>SwiftNet Online Operations Manager (O2M), a Swift Web Access service and the Secure Channel application on swift.com</li> <li>bridging servers (such as middleware or file transfer servers other than customer connectors) used for and <b>guardian of the secure data exchange</b> between back-office and Swift-related components</li> </ul> <p><b>Risk Drivers:</b></p> <ul style="list-style-type: none"> <li>password theft</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                               |                          |    |    |    |    |   |
| <p><b>Implementation Guidance</b></p> <p><b>Control Statement:</b></p> <p>Recorded passwords are stored in a protected physical or logical location, with access restricted on a need-to-know basis.</p> <p><b>Control Context:</b></p> <p>The secure storage of recorded passwords (repository) makes sure that passwords are not easily accessible to others, thereby protecting against simple password theft. Common unsecure methods include, but are not limited to: recording passwords in a spreadsheet or a text document saved in cleartext on a desktop, or in a shared directory, or a server, saved on a mobile phone, written/printed on a post-it or a leaflet.</p> <p>This control covers the storage of emergency, privileged or any other account passwords. All accounts have to be considered because (i) combination of compromised, not-privileged, accounts, such as transaction creator account and approver account can be damageable, and (ii) even monitoring accounts provide valuable information during the reconnaissance time.</p> <p><b>Implementation Guidelines:</b></p> <p>The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).</p> <ul style="list-style-type: none"> <li>Passwords written on physical media are protected through: <ul style="list-style-type: none"> <li>placing inside a sealed, tamper-evident security envelope</li> <li>storing in a safe</li> </ul> </li> </ul> |                          |    |    |    |    |   |

- logging the access to the storage location and which account passwords have been accessed.
- Passwords stored logically (digitally) are protected through:
  - Encryption-at-rest or obfuscation (that is, no plain text storage),
  - Authenticated access to the storage location, with access logging in line with or as part of the control 6.4.
- Passwords are not recorded in user manuals or other operational means unless the password is stored in line with the guidance above.
- If emergency access is granted to an operator who, under normal conditions, would not have access, then the password is changed immediately thereafter, and optionally, also the combination to the storage safe.
- Passwords are not hardcoded in scripts or other software code.

**Optional Enhancement:**

- The safe is certified through, for example, Underwriters Laboratories (UL) Class TL or EN-1143-1 certification.
- Apply the control to all bridging servers (such as middleware or file transfer servers other than customer connectors) used for data exchange between back-office and Swift-related components.